AUTHENTICATION & AUTHORIZATION

인증 조합·URL 권한 검증 보고서

LOOP Community 3.9.0 / Burp Workbench KR 0.43.0

작성일 2026.10.18 · 로컬 실습 환경 · 가상 계정과 학습용 데이터

검증 항목	실행 결과
인증 방식	세션, 토큰, JWT와 복합 조합 7개
독립 HTTP 검사	420개 통과 / 기록 요청 497회
실제 Burp 권한 비교	비교 기록 42건 / 기준 제외 계정 대조 126건
정상·취약 대조	정상 28건 기대 정책 일치 / 의도된 취약 14건 우회 의심
브라우저	104개 통과 / Chromium 146.0.7680.177
기존 기능 회귀	권한·업무 HTTP 384개, 커뮤니티 브라우저 66개 통과

판정 요약

검사한 정상 URL에서 비로그인 차단, 관리자 권한, 데이터 소유권과 쓰기 전후 상태를 기대한 대로 확인했습니다. 인증값 누락·혼합·변조·만료·폐기 후 재사용도 거부했습니다.

관리자 인가 누락과 객체 소유권 누락은 별도의 취약 실습 URL에서 의도적으로 재현했습니다. 같은 두 결함 유형을 7개 인증 방식에서 반복 관찰한 결과이며, 14개의 서로 다른 신규 취약점을 뜻하지 않습니다.

이 결과는 아래에 명시한 경로와 조건에 한정됩니다. 실습 사이트 전체의 안전성이나 다른 인증 시스템까지 보증하는 결과로 해석하지 않습니다.

1. 범위와 기대 권한

실습 페이지	필수 인증값
세션 쿠키 /auth-lab/session	Cookie: AUTHLABSID
불투명 토큰 /auth-lab/token	X-Auth-Token
JWT /auth-lab/jwt	Authorization: Bearer JWT
세션 + 토큰 /auth-lab/session-token	Cookie + X-Auth-Token
세션 + JWT /auth-lab/session-jwt	Cookie + Authorization
토큰 + JWT /auth-lab/token-jwt	X-Auth-Token + Authorization
세션 + 토큰 + JWT /auth-lab/all	Cookie + X-Auth-Token + Authorization

계정별 서버 정책

URL 기능	관리자	Alice	Bob	비로그인
회원 공통	200	200	200	401
관리자 회원 목록	200	403	403	401
Alice 요청 #901	200	200	404	401
Bob 요청 #902	200	404	200	401

인증 실습은 기존 JSESSIONID 커뮤니티 로그인과 구분합니다. 동일 로그인 묶음과 동일 인증 방식에 발급된 값을 함께 사용해야 합니다. 하나의 필수 값이 없거나 다른 계정·로그인의 값이 섞이면 401로 거부합니다. 쿠키가 포함된 변경 요청은 CSRF도 확인합니다.

2. 실행 환경과 결과 집계

항목	기록
실제 호스트	Burp Suite Community Edition 2026 3.3
확장	0.43.0 / 배포 JAR를 수정하지 않고 로드
전송	actual Burp Montoya HTTP
대상 서버	Tomcat 10.1.60 / Spring MVC / 별도 loopback 서버
DB	isolated H2 in Oracle compatibility mode
프로필	새 임시 Burp 프로필 / 기존 브라우저·프록시 설정 보존

방식별 실제 비교 기록

인증 방식	정상 대조	취약 대조	기준 제외 계정 대조
세션 쿠키	4	2	18
불투명 토큰	4	2	18
JWT	4	2	18
세션 + 토큰	4	2	18
세션 + JWT	4	2	18
토큰 + JWT	4	2	18
세션 + 토큰 + JWT	4	2	18
합계	28	14	126

비교 42건의 표에는 계정 칸이 168개 있습니다. 그중 42개는 기준 계정이며, 기준을 제외한 실제 계정 대조는 126개입니다. 사용자 신원·역할 및 독립 비로그인 검사는 21건, 만료 기준 중단 검사는 별도 1건입니다. 반복 실행 결과는 고유 검사 수에 더하지 않았습니다.

3. 의도된 인가 결함 대조

F-01 관리자 기능의 권한 검증 누락

구분	실제 관측
재현 경로	GET /api/auth-lab/{profile}/vuln/admin/users
기대 정책	관리자 허용 / 일반 사용자와 비로그인 거부
취약 대조	Alice·Bob이 HTTP 200으로 회원 목록 조회
정상 대응	/fixed/admin/users에서 Alice·Bob은 403, 비로그인은 401
확장 판정	EXT-039 : 우회 의심 / EXT-038 : 차단 응답 확인

응답의 AUTHLAB_ADMIN_DIRECTORY와 회원 데이터 포함 여부를 확인했습니다. 일반 사용자 200만으로 판단하지 않고 관리자 기준 응답, 서버 정책과 응답 내용까지 대조했습니다.

F-02 타인 객체의 소유권 검증 누락

구분	실제 관측
재현 경로	GET /api/auth-lab/{profile}/vuln/requests/901
기대 정책	Alice 소유 요청은 Alice·관리자만 조회
취약 대조	Bob이 HTTP 200으로 Alice의 비공개 메모 조회
정상 대응	/fixed/requests/901에서 Bob 404, 비로그인 401
확장 판정	EXT-042 : 우회 의심 / EXT-040 : 정책 일치

취약 실습의 Bob 메모 변경 요청은 실제 저장값 변화로 확인했습니다. 정상 URL의 동일 타인 변경은 404로 거부되었고 저장값도 유지되었습니다. 이 두 유형은 탐지 확인을 위해 제공한 대조 사례입니다.

4. 인증 오류와 쓰기 상태 증거

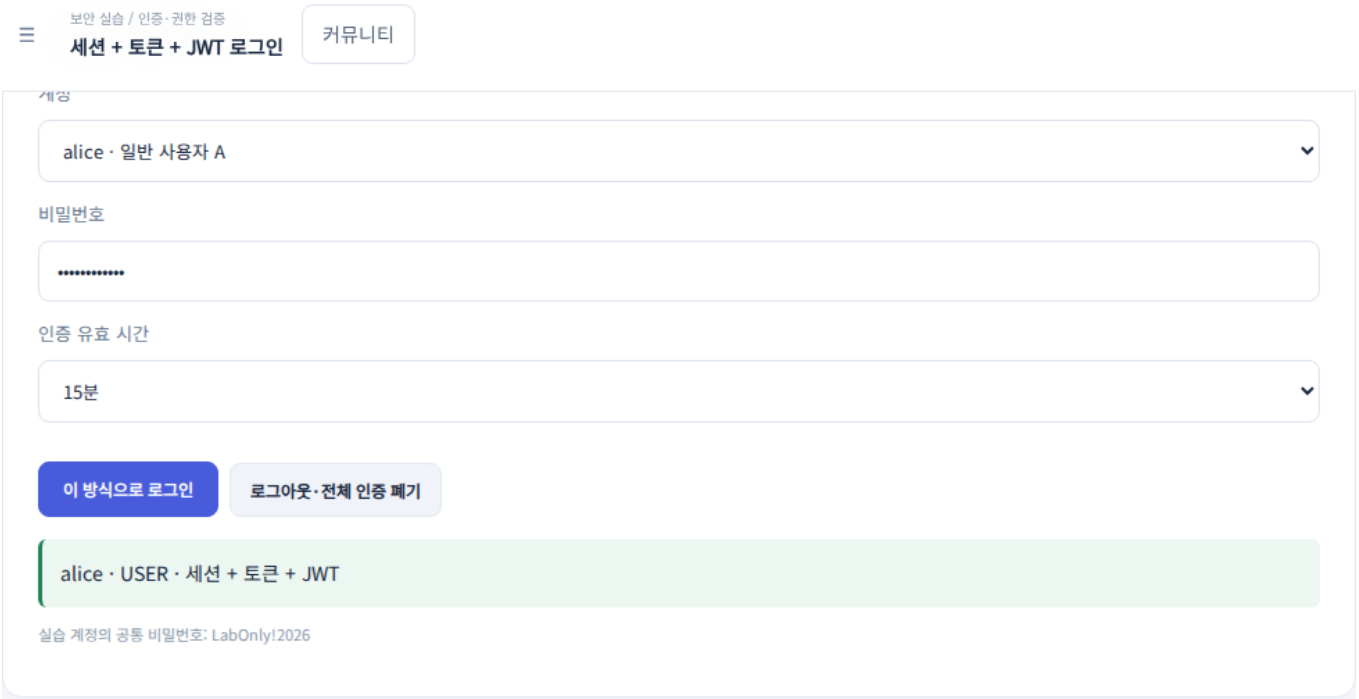
대표 검사	증거 ID	기대 / 실제
필수 쿠키 누락	HTTP-033	401 / 401
같은 사용자라도 다른 로그인 혼합	HTTP-166	401 / 401
중복 Authorization	HTTP-321	401 / 401
다른 인증 방식에 재사용	HTTP-324	401 / 401
JWT issuer 불일치	HTTP-327	401 / 401
JWT audience 불일치	HTTP-328	401 / 401
JWT 사용 시작 전	HTTP-330	401 / 401
alg=none	HTTP-336	401 / 401
JWT 본문 변조	HTTP-342	401 / 401
서명된 role 주장으로 승격 시도	HTTP-335	403 / 403
로그아웃 후 재사용	HTTP-401	401 / 401
유효 시간 만료	HTTP-414	401 / 401

쓰기 전후 확인

사례	HTTP	서버 상태
HTTP-038 타인 변경	404	변경 전후 동일
HTTP-043 소유자 변경	200	메모와 revision 증가 확인
HTTP-044 취약 대조 변경	200	타인의 실제 저장값 변경 확인

만료된 기준 요청을 저장된 200 응답과 함께 다시 비교했을 때, 확장은 현재 기준을 401로 재확인하고 모든 계정 재전송을 중단했습니다. 종합 결과는 녹색 차단이 아니라 '세션 확인 필요'였습니다.

5. 로그인 화면과 재현 순서



일곱 페이지에서 계정·유효 시간을 선택하고 직접 URL을 실행할 수 있습니다. 인증값은 접힌 상세에서 확인하고, 혼합·제외·JWT 변조와 실제 메모 변경을 재현할 수 있습니다.

1. 커뮤니티 사이드 메뉴에서 인증 방식별 로그인·권한 검증을 엽니다.

2. 각각의 로그인으로 admin·alice·bob의 요청을 수집합니다. 여러 계정을 동시에 비교할 때는 별도 브라우저 프로필을 사용합니다.

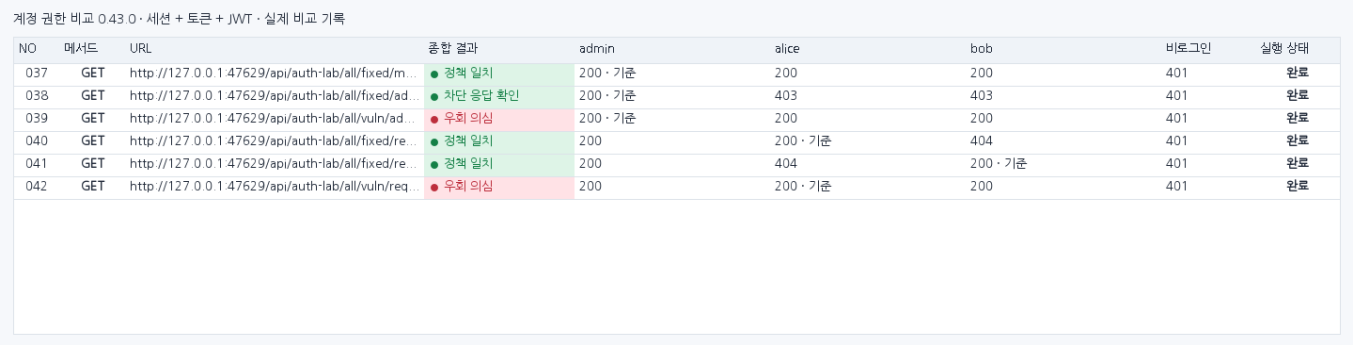
3. Workbench SCOPE에 로컬 실습 주소를 추가하고 수집을 SCOPE로 전환합니다.

4. 계정 권한 비교에서 관리자·일반·후보1·비로그인을 지정하고 정상 URL의 허용·차단 정책을 맞춥니다.

5. 사용자 확인 URL은 /api/auth-lab/{profile}/me, 신원 경로는 $.user.id, 역할 경로는 $.user.role입니다.

6. 요청을 선택해 비교하고 계정별 응답과 종합 결과를 확인합니다. 취약 URL에서는 의도된 우회 의심을 대조합니다.

6. 실제 확장 기록과 검사 구분



계정 권한 비교 0.43.0 · 세션 + 토큰 + JWT · 실제 비교 기록

NO	메서드	URL	종합 결과	admin	alice	bob	비로그인	실행 상태
037	GET	http://127.0.0.1:47629/api/auth-lab/all/fixed/m…	정책 일치	200 · 기준	200	200	401	완료
038	GET	http://127.0.0.1:47629/api/auth-lab/all/fixed/ad…	차단 응답 확인	200 · 기준	403	403	401	완료
039	GET	http://127.0.0.1:47629/api/auth-lab/all/vuln/ad…	우회 의심	200 · 기준	200	200	401	완료
040	GET	http://127.0.0.1:47629/api/auth-lab/all/fixed/re…	정책 일치	200	200 · 기준	404	401	완료
041	GET	http://127.0.0.1:47629/api/auth-lab/all/fixed/re…	정책 일치	200	404	200 · 기준	401	완료
042	GET	http://127.0.0.1:47629/api/auth-lab/all/vuln/req…	우회 의심	200	200 · 기준	200	401	완료

위 이미지는 실제 Burp에 로드한 확장 컨트롤러의 비교 기록 표를 렌더링한 것입니다. 인증값을 보여 주는 후보·패킷 영역은 제외했습니다. 근거 JSON의 responseSha256은 Burp가 반환한 본문 문자열을 UTF-8로 인코딩한 해시이며 전송 바이트 해시와 구분합니다.

분류	범위와 통과 수
인증·전송 조건	112
JWT·역할 위조	71
일반 권한·객체·현재 DB 역할	117
CSRF·만료·폐기	36
실제 쓰기·의도된 취약 대조	84
독립 HTTP 검사 합계	420

확장 테스트는 실제 Montoya 요청·응답과 운영 비교 컨트롤러를 사용했습니다. 자동 하네스가 계정 후보를 지정하고 비교 실행 경로를 호출했으며, 사람이 Burp 창을 클릭한 검사는 아닙니다. 브라우저 104개 검사는 별도 Chromium으로 웹 페이지를 조작한 결과입니다.

7. 배포·근거와 검증 한계

검증된 배포 파일

확장 JAR: burp-workbench-kr-0.43.0.jar

0b6a1147ae8cad653e7f6995aaf55f80082cb2dd49fe333a0b871224404134e1

커뮤니티 실행 ZIP: community-security-lab-3.9.0-docker.zip

a9d32758e06950e6135a9498a2d3d68c6951c53c89aecf129f5cb8ac7076817c

검사 재현

기본 CI: python tools/check_auth_lab.py --mode adapter
웹 페이지: python tools/check_community_ui.py --auth-lab
실제 Burp: check_auth_lab.py의 native 모드에 별도 Burp JAR·Java 21 경로와 라이선스 수락 옵션을 지정합니다.

실행 환경과 남은 범위

상세 420개와 실제 Burp 비교는 격리된 H2 Oracle 호환 모드에서 실행했습니다. 실제 Burp 창의 클릭·물리 키·Windows DPI/IME, 외부 운영 사이트, OAuth/OIDC·SAML·JWE·RS256 발급 시스템은 이번 검사에 포함하지 않습니다. HTTP 실습 쿠키의 Secure 동작은 HTTPS 환경 검증과 구분합니다.

Burp 헤드리스 시작 시 내부 ComponentUI 경고 2건이 기록되었습니다. 비교 컨트롤러·HTTP·종료 검사는 통과했으며 실제 호스트 GUI 표시는 검증하지 않았습니다.

원격 검사

실제 Docker·Oracle·Nginx의 인증 경계 197개·기존 HTTP 54개, 최종 소스 Build·Chromium 검사와 동일 런타임의 Windows·Linux 안정성 검사가 성공했습니다. 안정성 검사 입력 373개는 최종 소스와 바이트가 같습니다. 반복 수는 합산하지 않았습니다.

Oracle·Nginx 인증 경로 대조: 197개 통과.

기존 트래픽 비동기 검색 회귀가 한 차례 실패한 뒤 분리 재실행 23개를 통과했습니다. 해당 0.43.0 소스·검사는 바꾸지 않았으며 최종 전체 배포 검사 결과와 실패 이력을 상세 검증 JSON에 함께 남겼습니다.

첨부 근거

summary.json: 실행 환경과 수치
http-results.json: 420개 기대/실제 결과와 가린 요청·응답
extension-results.json: 계정별 판정·응답 근거·본문 문자열 해시
ui-results.json: 실제 브라우저 동작과 화면 목록

참고 기준

RFC 7519: https://www.rfc-editor.org/rfc/rfc7519.html
RFC 8725: https://www.rfc-editor.org/rfc/rfc8725.html
저장소: https://github.com/ohjun1998/burp-workbench-kr